Task 1: Deploy a test cloud virtual machine

For this exercise, you can use an AWS EC2 instance or an equivalent VM in another cloud provider.

Procedure
1. Open the cloud provider's management console.
2. Create a small test VM using an appropriate supported operating system.
3. Configure a strong authentication method.
4. Restrict inbound network access to your own IP address wherever possible.
5. Avoid exposing administration ports such as SSH (22) or RDP (3389) to the entire internet.
6. Record the operating system, instance details, and security-group rules.

Security note: Do not intentionally expose a VM with unrestricted default settings to the internet simply to make it vulnerable. Use a controlled lab and deliberately configure only the test conditions you need.

Task 2: Run a vulnerability scan

For a basic web-server assessment, Nikto can be used against a web server you own. For a broader host vulnerability assessment, OpenVAS/Greenbone Community Edition is another option.

Example Nikto command:

```
nikto -h http://YOUR-TEST-VM-IP
```

Replace YOUR-TEST-VM-IP with your authorized test VM's address. Ensure the web server is running and reachable from the scanner.

Procedure

1. Install the scanner on your lab machine.
2. Confirm network reachability to your authorized VM.
3. Run the scan against the target service.
4. Save the output to a report file if supported by your installed version.
5. Review each finding and verify whether it is a genuine vulnerability, a configuration warning, or a false positive.

Task 3: Document vulnerabilities and mitigation strategies

Vulnerability	Potential impact	Recommended mitigation
Unnecessary open port	Increases the attack surface and may expose an unwanted service	Close the port or restrict it through firewall/security-group rules.
Outdated software package	Known vulnerabilities may be exploitable	Apply supported security updates and patches.
Directory listing enabled	File names or unintended resources may be exposed	Disable directory indexing and review public directories.

Task 4: Implement one mitigation and rescan

Example: Closing an unnecessary port
1. Identify an open port reported by your scan.
2. Confirm whether the service is required.
3. If it is unnecessary, remove the corresponding inbound rule from the cloud security group or firewall.
4. Confirm that you have not blocked essential management access.
5. Rerun the scan.
6. Compare the new result with the original report.

Before mitigation	After mitigation
Unnecessary port was accessible from the scanner.	The port is no longer reachable from the scanner's network.
Service increased the exposed attack surface.	Network exposure is reduced.

Task 5: Share findings and discuss business impact

The results can be shared in a report or class discussion, excluding passwords, keys, public IP details that should remain private, and other sensitive information.

Example discussion:

In a Zomato-style food delivery application, an outdated public-facing service could allow attackers to exploit a known software vulnerability. Unauthorized access might expose customer or order information, disrupt delivery operations, or provide a route into other systems.

In a Paytm-style payment application, inadequate access controls or unpatched services could put sensitive transaction-related information at risk. Restricting network access, applying security patches, encrypting data, and monitoring suspicious activity help reduce these risks.

The actual impact depends on the vulnerability, the application's architecture, and the controls in place.